

THE TANGLED WEB OF

Password Reuse

A Critique of Das, Bonneau, Caesar, Borisov & Wang

CS 4339.0W1 – Assignment #1

Roshini Lidwin & Tipper Truong

What the Paper Is About

The authors argue that the real security weakness is **user behavior**, not flaws in any single website.

Because remembering many strong passwords is hard, people reuse or only slightly change one password across many sites. If one site is breached, that leaked password can open the user's other accounts.

Our thesis

The paper makes a strong, well-supported case that password reuse is a real security risk, but its data has limits and some conclusions are now dated.

Study Cases

- 43–51% of users reuse passwords across sites.
- Hundreds of thousands of leaked passwords from 11 sites were analyzed, plus a user survey.
- The authors introduce the first cross-site password-guessing algorithm.
- It guesses ~30% of modified passwords within 100 attempts, versus 14% for traditional methods.



Why Password Reuse Happens

- Passwords are still the primary way users protect online accounts.
- Most people have many online accounts, making unique passwords difficult to remember.
- Many users reuse the same password or make only small changes for different websites.
- If one website is breached, attackers can use the leaked password to access other accounts.



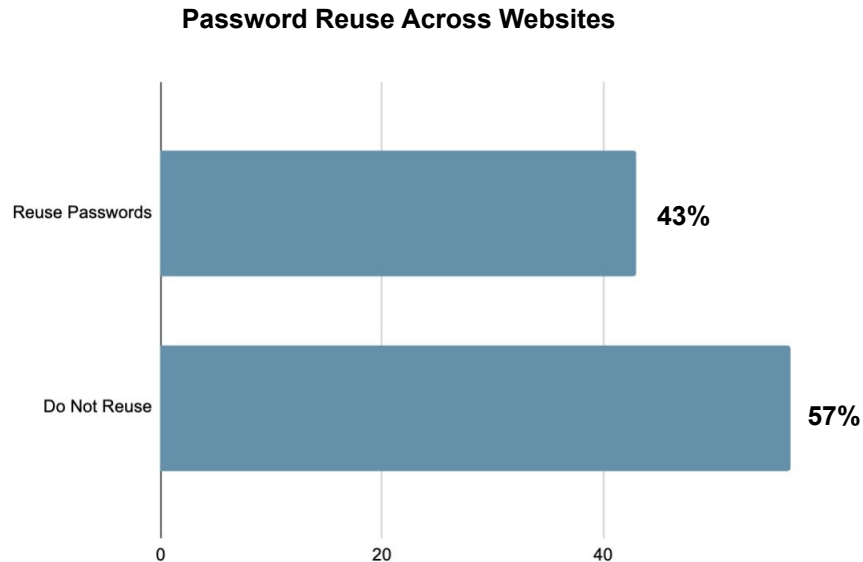
How the Research Was Conducted

- The researchers analyzed several hundred thousand leaked passwords.
- The passwords came from 11 different websites.
- They also conducted a survey with over 200 participants.
- Using leaked password data and survey responses made the study more reliable.



Main Findings

- About 43% of users reused the exact same password.
- Overall, 43-51% of users reused passwords across websites.
- Many users only made small changes to existing passwords.
- The survey supported these findings.



Common Password Patterns

- Users often add numbers, symbols, or capital letters.
- Many simply add characters to the end of a password.
- These changes follow predictable patterns.
- This makes modified passwords easier for attackers to guess.

123456
qwerty
password
qwerty123
Baseball

123456!
qwerty12!
pa\$\$word1
Qwerty123*
Baseball1!

Cross Site Password Guessing

- The authors created the first cross-site password guessing algorithm.
- The algorithm starts with one leaked password.
- It applies common password changes used by real users.
- It guessed about 30% of modified passwords within 100 attempts.
- Traditional password guessing only guessed about 14%.



What the Paper Does Well

It measures the problem

Instead of just calling reuse “bad,” the paper shows how bad with a real number: the guesser cracks about 30% of modified passwords in 100 tries, versus only 14% for traditional guessing.



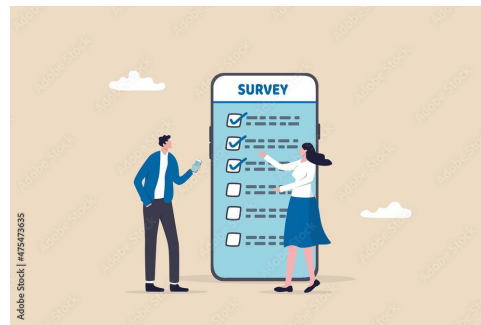
It is clear and honest

The threat model is stated plainly that the attacker already holds one leaked password, so the authors don't overclaim their findings. Pairing leaked data with a survey lets each method support the other, making the findings more reliable.



Where the Paper Falls Short

- **The data isn't a random sample**
 - Leaked passwords come only from breached sites, and weak passwords are overrepresented. So, the 43-51% reuse number should be read as a rough estimate, not a hard fact as they claim.
- **Self reporting bias**
 - The survey the authors conducted relies on other people honesty.
 - This is risky as people might be lying about what they put down. Which can skew the reported behavior.
- **An ethical gray area**
 - Building a guessing tool from real leaked passwords raises concerns.
 - The paper doesn't spend much time addressing, even though the data was already public.



The Biggest Issue Is Age

- The research paper came first before multi-factor authentication, password managers, breach alerts, and passkeys.
- All of these reduce the damage a leaked password can do. Even with a correct password the attacker now faces extra hurdles, and users get alerted before they could access the account.

This does not make the paper wrong.

- Reuse is still common and attackers still exploit leaked passwords.
 - But the paper's numbers should be seen as a snapshot and reminder of its time, not today.
- An updated study including these modern tools and defenses would give a clearer picture of an accurate number. Thus, making the paper even stronger than it is now.

Conclusion

- Password reuse remains a major cybersecurity risk.
- Small password changes are often predictable.
- The study used leaked password data, surveys, and a password guessing algorithm to support its findings.
- Creating a unique password for every account is still the safest approach.
- Future research should study password reuse with newer security tools such as passkeys and multi-factor authentication.

Reference

Das, A., Bonneau, J., Caesar, M., Borisov, N., & Wang, X. (2014). *The Tangled Web of Password Reuse*. Proceedings of the Network and Distributed System Security Symposium (NDSS 2014).